HỌC VIỆN CÔNG NGHỆ BƯU CHÍNH VIỄN THÔNG
Posts and Telecommunications Institute of Technology

VIỆN KHOA HỌC KỸ THUẬT BƯU ĐIỆN
Reseach Institute of Posts and Telecommunications

TrustMesh

Trust, Authorization và Monitoring trong hệ phân tán

Chương 9.4–9.7

Vũ Văn Hùng

Hoàng Văn Huynh - B23DCCC086

Nội dung trình bày

Trust

Byzantine, 3k+1, Sybil, hash chain và blockchain.

9.4 Vũ Văn Hùng

Authorization

Mô hình, MAC/DAC/RBAC/ABAC, ACL, capability, delegation.

9.5 Hoàng Văn Huynh

Giám sát

Firewall, SIDS/AIDS, CIDS, metrics, demo và kết luận.

9.6–9.7 Huynh · Hùng

Câu hỏi xuyên suốt

Khi các node không hoàn toàn tin nhau, hệ thống dựa vào cơ chế nào để cấp quyền và nhận ra tấn công?

Trust → Authorization → Monitoring

Ví dụ xuyên suốt: Mallory muốn sửa bảng điểm



Alice: đọc hợp lệ

Bob: được ủy quyền

Carol: nhận quyền ủy

Mallory: kẻ tấn công

Trust

Vé và cảnh báo có chữ ký; khóa của peer được ghim.

Authorization

MAC và ABAC, vé do node ký, mặc định từ chối.

Monitoring

Audit hash chain, AIDS/SIDS ở từng node, quorum hai reporter.

9.4 Trust: chọn bằng chứng nào được chấp nhận

Node · đường truyền · phần mềm
đều có thể sai hoặc bị chiếm

→

Bằng chứng
chữ ký số, hash, khóa công khai đã biết trước

→

Chấp nhận / từ chối
tin cả nhóm, không tin từng node

Node nói dối

Gửi giá trị mâu thuẫn cho từng peer.

9.4.1

Nhiều node giả

Một kẻ tạo nhiều danh tính để chiếm đa số.

9.4.2

Sửa log

Xóa hoặc đổi bản ghi cũ để che dấu vết.

9.4.3

TrustMesh

Mỗi node ghim khóa Ed25519 của peer, tự kiểm chữ ký trên vé và cảnh báo, không hỏi lại node đã ký.

Byzantine: node có thể nói dối



Crash

nhẹ

Node dừng hẳn, không trả lời nữa.

Omission

vừa

Node mất hoặc bỏ qua một số thông điệp.

Byzantine

nặng nhất

Node gửi giá trị tùy ý, kể cả mâu thuẫn.

Cách chống

Nhân bản và biểu quyết đa số; ký thông điệp để lộ mâu thuẫn. Không tin một node, tin đa số trung thực.

Giới hạn n ≥ 3k + 1

$$n \geq 3k+1$$

n: tổng số node trong nhóm
k: số node xấu tối đa hệ thống chịu được
quorum: cần n − k phản hồi khớp nhau

Cần bao nhiêu node?

k = 0 $n \geq 1$ ●

k = 1 $n \geq 4$ ●●●●

k = 2 $n \geq 7$ ●●●●●●●

k = 3 $n \geq 10$ ●●●●●●●●●●

Vì sao 3k + 1

Node xấu có thể im lặng hoặc nói dối; phần còn lại vẫn phải thắng đa số.

TrustMesh: n = 3

Byzantine chịu được k = 0, chưa đủ. Dùng chữ ký và quorum 2 reporter độc lập cho cảnh báo.

Sybil: nhiều danh tính giả



CA tập trung

Cấp và ràng buộc danh tính.

Phi tập trung

PoW, PoS hoặc reputation làm danh tính tốn kém.

TrustMesh

Cụm đóng: chỉ khóa đã ghim mới được tham gia.

Hậu quả của Sybil

Tăng quyền biểu quyết, cô lập node trung thực. Phá vỡ giả định mỗi danh tính là một thực thể.

Hash chain và blockchain

Bản ghi #1

```
prev: 0000
data: điểm: 8.0
hash: a1f3
```

→

Bản ghi #2

```
prev: a1f3
data: điểm: 10.0
hash: 9c7e
```

đã bị sửa → hash đổi

→

Bản ghi #3

```
prev: b72d
data: điểm: 7.5
hash: e0c5
```

prev lệch → chuỗi đứt

Hash chain

Mỗi bản ghi chứa hash của bản ghi trước; sửa một bản ghi làm các bản sau lệch.

Blockchain

Hash chain nhân bản, đồng thuận giữa nhiều bên; khó sửa đồng thời mọi bản sao.

Giới hạn

Chỉ phát hiện sửa, không ngăn được. Vẫn phải tin implementation và consensus.

TrustMesh

Mallory sửa audit log của node-a: chuỗi hash đứt, node-b và node-c còn bằng chứng.

Vì sao bảo mật phân tán khó

1
Đồng hồ
Không có đồng hồ toàn cục chung.

2
Lỗi riêng
Một node hỏng, phần còn lại vẫn chạy.

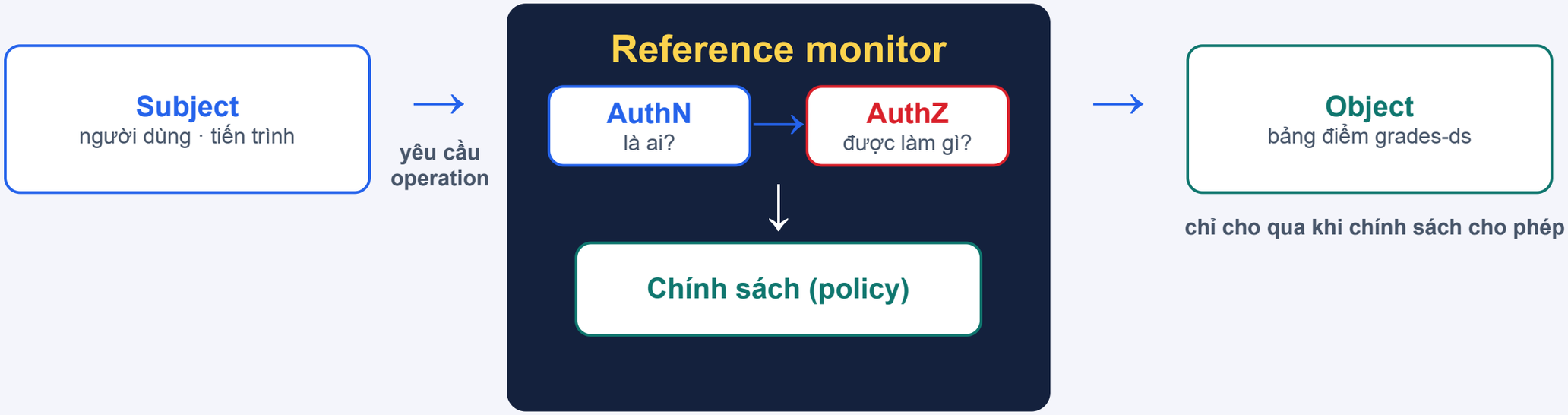
3
Mạng
Thông điệp có thể trễ, mất hoặc đảo thứ tự.

4
Đồng thời
Nhiều tiến trình cùng truy cập dữ liệu chung.

5
Không điểm duy nhất
Không có một cổng kiểm soát chung.

Hệ quả cho bảo mật
Chính sách phải được thực thi ở từng node; không thể dựa vào một cổng duy nhất hay một đồng hồ chung.

9.5 Mô hình authorization



Chống sửa đổi

Kẻ tấn công không thể đổi reference monitor.

Không thể bị bỏ qua

Mọi đường truy cập đều đi qua.

Đủ nhỏ để kiểm chứng

Fail-safe default: không khớp thì từ chối.

MAC, DAC, RBAC, ABAC

MAC

Nhãn bảo mật do quản trị trung tâm đặt.

tập trung

DAC

Chủ sở hữu tự trao quyền cho người khác.

chủ sở hữu

RBAC

Quyền gắn với vai trò, người dùng nhận vai trò.

vai trò

ABAC

Xét thuộc tính người dùng, tài nguyên và môi trường.

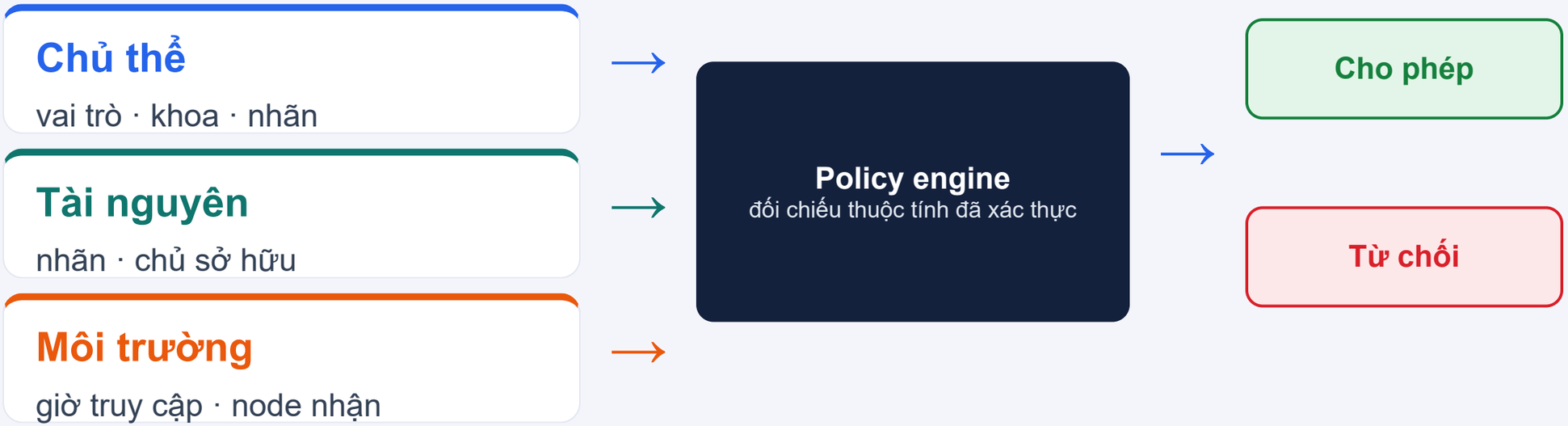
thuộc tính

đơn giản, cứng

chi tiết, linh hoạt

ABAC: chi tiết hơn nhưng chính sách phức tạp, khó kiểm tra.

ABAC trong TrustMesh



Alice

Đúng vai trò và khoa: ABAC cho đọc.

Mallory

Nhãn thấp hơn bảng điểm: MAC chặn.

Tự khai admin

Thuộc tính tự khai bị bỏ qua.

ACL và capability

ACL · theo object

Quyền lưu cùng với tài nguyên.

`grades-ds`

Alice	`read`
Bob	`read`
Mallory	—

⇄

Capability · theo subject

Bằng chứng quyền do subject giữ, server xác minh token.

```
holder: Bob
op: read · grades-ds
hạn: ngắn
chữ ký: Ed25519 ✓
```

vé TrustMesh = capability có chữ ký

Capability cần chống sửa vé, dùng lại vé, vé quá hạn; thu hồi khó nên dùng hạn ngắn và danh sách thu hồi.

9.5.3 Delegation và OAuth

node-a / Alice
quyền gốc: read + write

→ ký vé

Bob
read · hạn 1 giờ

→ ủy lại

Carol
read · hạn 15 phút

Không mở rộng
quyền chỉ thu hẹp hoặc giữ nguyên

Delegation

Cho bên khác hành động thay mình mà không đưa mật khẩu.

OAuth

Token có scope và thời hạn thay cho mật khẩu của người dùng.

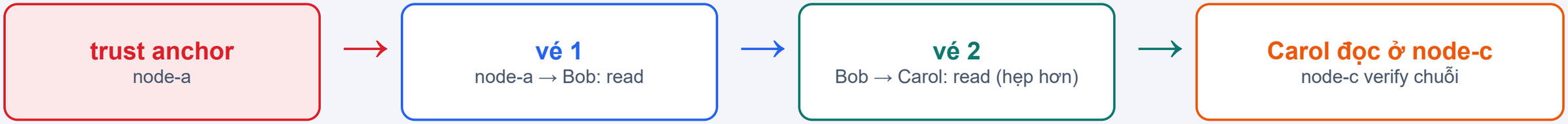
Trong TrustMesh

node-a ký vé cho Bob; Bob ủy lại cho Carol với quyền hẹp hơn. node-b, node-c tự kiểm chữ ký.

Rủi ro cần chặn

Vé bị đánh cắp · vé quá hạn · mở rộng quyền khi ủy tiếp.

WAVE và chuỗi delegation



Verifier duyệt **ngược** chuỗi attestation từ vé 2 về trust anchor, kiểm từng chữ ký và từng bước thu hẹp quyền.

WAVE

Biểu diễn ủy quyền bằng đồ thị attestation.

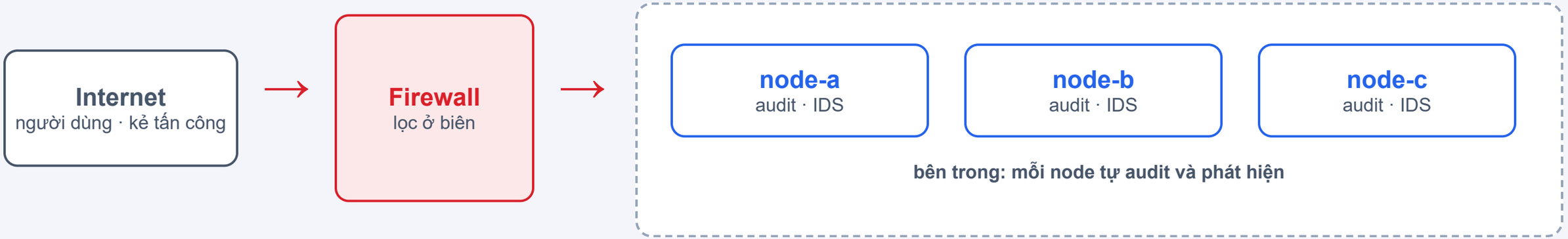
Mỗi mắt xích

Thu hẹp quyền của mắt trước, không mở rộng.

Không hỏi lại

node-b, node-c không gọi lại node cấp vé.

9.6 Firewall và giám sát



Tài khoản hợp lệ bị chiếm vẫn đi qua firewall như lưu lượng bình thường

Chặn

Cổng, địa chỉ, giao thức không hợp lệ.

Bỏ sót

Lưu lượng bình thường nhưng ý đồ xấu.

Cần thêm

Audit và phát hiện xâm nhập bên trong.

Firewall không thay thế authorization.

SIDS và AIDS

SIDS · theo chữ ký

Khớp mẫu tấn công đã biết, dễ giải thích.

Gói tin → Khớp mẫu? → Cảnh báo

dễ giải thích | yếu với zero-day

AIDS · theo bất thường

Học hành vi bình thường, tìm điều lệch chuẩn.

Hành vi → Lệch chuẩn? → Cảnh báo

bắt được tấn công mới | dễ báo nhầm

SIDS ở node-b

Nhận ra path traversal bằng mẫu đã biết.

AIDS ở node-a, node-c

Ba lần bị từ chối liên tiếp là bất thường.

Một cảnh báo

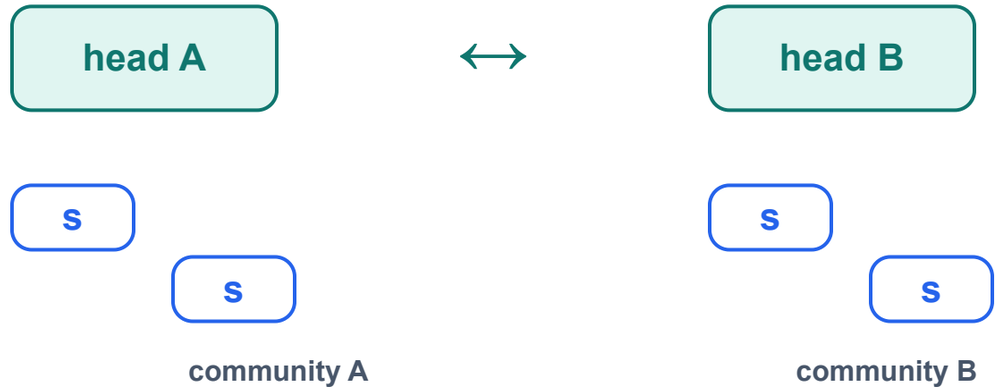
chưa là sự cố; cần quorum nhiều reporter.

Collaborative IDS (CIDS)

CIDS tập trung



CIDS phân tán



Tập trung

Chính xác hơn nhưng dễ nghẽn, một điểm lỗi.

Phân tán

Mở rộng tốt, không có điểm lỗi duy nhất.

TrustMesh

Hai reporter độc lập tạo quorum.

Đánh giá IDS: TP, FP, FN, TN

	thực tế: tấn công	thực tế: bình thường
IDS báo tấn công	**TP** cảnh báo đúng	**FP** báo nhầm
IDS báo bình thường	**FN** bỏ sót tấn công	**TN** bỏ qua đúng

Accuracy

`(TP + TN) / tổng số mẫu`

Precision

`TP / (TP + FP)`

Cảnh báo đúng bao nhiêu phần.

Base rate

Tấn công hiếm thì FP lấn át cảnh báo. Ví dụ minh họa: tấn công 1%, FP 5% → precision chỉ khoảng 17%. Vì vậy theo dõi precision, đừng chỉ đếm số cảnh báo.

Demo: Mallory muốn sửa bảng điểm

1

Ai được đọc bảng điểm?

Alice đọc được (ABAC), Mallory bị MAC chặn, tự khai admin bị bỏ qua.

9.5.1–9.5.2

2

Ủy quyền qua ba node

node-a ký vé cho Bob, Bob ủy Carol, Carol đọc ở node-c.

9.5.3

3

Mallory đổi chiến thuật

Vé đánh cắp, vé giả đều bị từ chối; AIDS và SIDS đủ quorum.

9.4, 9.6

4

Xóa dấu vết

Sửa audit log node-a, chuỗi hash đứt; node-b, c còn bằng chứng.

9.4.3

Partial failure

Tắt node B, bấm R, chạy lại 1 → 4: hai node còn lại vẫn phục vụ.

Kết luận 9.7

Trust

Không loại bỏ nhu cầu kiểm chứng.

Authorization

Mặc định từ chối, giới hạn delegation.

Monitoring

Kết hợp nhiều điểm quan sát.

Partial failure

Một node hỏng chỉ giảm năng lực, không dừng cả hệ thống.

Thông điệp chính

Một cơ chế đơn lẻ không đủ. Tin giả định về cả nhóm, và kiểm chứng từng bằng chứng.

Cảm ơn thầy và các bạn đã lắng nghe

Hỏi đáp

Vũ Văn Hùng

Hoàng Văn Huynh - B23DCCC086